Contents

1 Firmware Security Assessment Report — Naxclow A9/V720 "cam170" 1
- 1.1 Executive Summary . . . 1
  - 1.1.1 Assessment Overview . . . 1
  - 1.1.2 Key Findings . . . 1
  - 1.1.3 Risk Summary . . . 1
  - 1.1.4 Recommendations Priority . . . 2
- 1.2 Table of Contents . . . 2
- 1.3 Scope and Methodology . . . 2
  - 1.3.1 Assessment Scope . . . 2
  - 1.3.2 Methodology . . . 2
  - 1.3.3 Tools Used . . . 3
- 1.4 Findings . . . 3
- 1.5 Technical Analysis Details . . . 3
  - 1.5.1 Architecture . . . 3
  - 1.5.2 Security mitigations . . . 4
  - 1.5.3 Network services . . . 4
- 1.6 Remediation Roadmap . . . 4
  - 1.6.1 Phase 1 — Owner-side, immediate (no vendor dependency) . . . 4
  - 1.6.2 Phase 2 — Device-side (if vendor/SDK work is ever pursued) . . . 4
  - 1.6.3 Phase 3 — Goal-aligned decision (better AV) . . . 4
- 1.7 Appendices . . . 5
  - 1.7.1 A. Evidence inventory . . . 5
  - 1.7.2 B. CVSS calculation table . . . 5
  - 1.7.3 C. Limitations & operational notes . . . 5

1 Firmware Security Assessment Report — Naxclow A9/V720 "cam170"

Client: Internal (Andy / 0x3d, CatCam project) **Product:** Naxclow-branded A9/V720 mini IP camera (batch `A9_X4_V12`, Beken BK7252 SoC, gc0312 sensor) **Firmware Version:** 202503081631 (previously observed: 202411201737; scheme = build timestamp) **Assessment Period:** 2026-10-02 → 2026-10-03 **Report Date:** 2026-10-03 **Assessed By:** Andy (0x3d) with OpenFox agent

---

1.1 Executive Summary

1.1.1 Assessment Overview

Security assessment of the Naxclow/V720 cat-camera at 10.0.0.170 (UID `080c0e054577`), conducted on a dedicated LAN where the device's entire cloud stack (HTTP rendezvous, MQTT control, TCP P2P video) is DNS-sinkholed into the open-source CatCam Go relay. The device exposes **zero LAN listeners** — all attack surface lives in its outbound cloud protocol, which the sinkhole lets us observe and control end-to-end.

1.1.2 Key Findings

Critical Issues: 0 **High Severity:** 2 (FW-001, FW-005) **Medium Severity:** 6 **Low Severity:** 0 **Informational:** 0

1.1.3 Risk Summary

The device has **no integrity protection of its control plane**: rendezvous, MQTT and P2P commands run in cleartext with per-boot rotating tokens that only the (unauthenticated) server knows — meaning

whoever answers the device's DNS *is* its cloud, with full command, streaming and OTA reach. In this environment that position is (intentionally) occupied by the CatCam relay, which has run in production for months — simultaneously the strongest possible proof of FW-001 and the recommended interim mitigation. OTA is a plausible fleet-wide implant vector (FW-005, candidate on the current build: mechanism verified, signature-gate status unknown). Firmware acquisition confirmed the device runs the newest vendor build in existence: no quality upgrade is available on stock hardware, and the VGA-class sensor caps any firmware-side improvement.

1.1.4 Recommendations Priority

1. **Keep the sinkhole** (all cameras, always) — addresses FW-001..FW-005 in one move on the owner side; no vendor fix will arrive.
2. Segment cameras onto an isolated IoT VLAN with default-deny + explicit relay-only exception.
3. For image-quality goals: replace hardware (OpenIPC-supported 5 MP unit); do not flash older/mismatched RBL builds onto cam170.

1.2 Table of Contents

1. Executive Summary
2. Scope and Methodology
3. Findings
4. Technical Analysis Details
5. Remediation Roadmap
6. Appendices

1.3 Scope and Methodology

1.3.1 Assessment Scope

In scope: device fingerprinting; cloud-protocol attack surface (HTTP/MQTT/TCP); firmware acquisition from the vendor OTA infrastructure; RBL container analysis; protocol PoCs (reboot executed while idle); OTA feasibility assessment.

Out of scope: hardware teardown (no desoldering/SPI this round), app-side cloud API abuse, cam199 (used only as a UID-pair control), any persistent modification or flashing of the device.

1.3.2 Methodology

1. **Baseline recon** — ARP/neighbour, full 65 535-port scan (none open), relay/nginx log mining, MQTT observation.
2. **Firmware acquisition** — enumeration of the vendor OTA server (`120.77.233.10/BK7252_P2P_IPC_FW`, the `dl2.naxclow.com` content host) and download of 3 A9-family builds; SHA-256 logged. One **3-minute controlled un-sinkhole probe** captured the device's live confcheck answer from the real cloud (restored automatically; sinkhole integrity verified afterwards — see gotcha note in Appendix C).
3. **Extraction** — unblob (absent on host) → binwalk (`-B` + `-e --matryoshka`): RBL payloads are AES-encrypted, zero signatures; unresolved region 100 %.
4. **Static analysis** — RBL headers; upstream artifacts from git history (`docs/uart.log` serial boot log, app JADX sources); live boot pcap dissection.
5. **Dynamic protocol testing** — PoC-01..04 (MQTT unauth control, relay/TCP command injection, rogue confcheck, UID sweep).
6. **Feasibility study** — upgrade-path research (OpenIPC/OpenBeken/vendor SDK).

1.3.3 Tools Used

tcpdump/tshark, mosquitto_pub/sub, curl, binwalk, ent, Python 3 (custom PoCs, cvss lib 3.6), CatCam Go relay (production sinkhole), nanomq broker logs, nginx sinkhole access logs.

1.4 Findings

ID	Title	Severity	CVSS 3.1	Status
FW-001	Unauthenticated cleartext HTTP rendezvous → MitM becomes the device's cloud	High	7.7	Verified
FW-002	Unauthenticated MQTT device control (any LAN client)	Medium	6.3	Verified
FW-003	TCP P2P channel executes forwarded commands w/o device-side check	Medium	6.3	Verified
FW-004	Cleartext credentials + telemetry (MQTT CONNECT, HTTP URIs)	Medium	4.3	Verified
FW-005	OTA over plaintext HTTP, integrity unverifiable	High	8.1	Mechanism verified / current-build impact candidate
FW-006	Sequential UIDs enable batch enumeration	Medium	4.3	Verified
FW-007	Factory SoftAP with no password	Medium	5.0	Verified on 2022 build / candidate current
FW-008	Root `msh` shell on debug UART	Medium	6.8	Verified on 2022 build / candidate current

Full details, PoCs and remediation per finding: `findings/`.

1.5 Technical Analysis Details

1.5.1 Architecture

- SoC **Beken BK7252** (Wi-Fi/BLE SoC) running **RT-Thread 3.1.0** + FAL 0.4.0 + RT-Thread OTA 0.2.4; app partition at flash `0x10000`. No Linux/rootfs exists.
- Sensor **gc0312** → JPEG **640×480 @ ~12 fps (~7.6 KB/frame)**, audio G.711 A-law 8 kHz; MJPEG/G.711 multiplexed over a reliable-UDP data channel (pkgID window + code-605 selective ARQ) with TCP control.

- Firmware images: **RBL** container (magic `RBL\0`, unix build-time @0x08, name @0x20, default key-string `00010203040506070809` @0x40), AES payload (entropy 8.000 bits/byte).

1.5.2 Security mitigations

Mitigation	Status	Notes
TLS anywhere in device stack	**Absent**	HTTP/MQTT/TCP all cleartext (verified)
Server authentication	**Absent**	confcheck answer executed verbatim (verified — production sinkhole)
Message-level signing of commands	**Absent**	anonymous MQTT/TCP commands executed (verified)
Image encryption at rest	Present	AES-RBL; key not recovered
Image signature enforcement at flash	**Unknown**	boot log shows CRC-verify→recovery only; current build untested (candidate)
ASLR/canaries/RELRO	n/a	flat RTOS image
Debug console lockdown	**Absent** (2022 build)	`msh />` UART shell unauthenticated

1.5.3 Network services

- Device: **none listening** (connect-only; verified full port scan).
- Outbound: HTTP/80 rendezvous + alerts (~30 s beacon), MQTT/1883 control, TCP+UDP P2P data channel; sinkholed by design on this LAN (`*.naxclow.com → 10.0.0.2`).

1.6 Remediation Roadmap

1.6.1 Phase 1 — Owner-side, immediate (no vendor dependency)

1. Keep DNS sinkhole + relay for every unit permanently (FW-001..005).
2. IoT VLAN default-deny; only relay endpoint reachable (FW-002/003/006).
3. Disable/replace app-cloud pairing; remove vendor account binding if retention not needed (FW-004 exposure).

1.6.2 Phase 2 — Device-side (if vendor/SDK work is ever pursued)

1. TLS + cert pinning; per-device credentials; signed commands (FW-001..004).
2. Signed, downgrade-protected OTA over HTTPS; retire plaintext mirrors (FW-005).
3. Production fuse for UART console; password-protected provisioning AP (FW-007/008).

1.6.3 Phase 3 — Goal-aligned decision (better AV)

Stay on 202503081631 (newest public build). Sensor caps quality; hardware replacement is the only real upgrade. See `firmware-upgrade-feasibility.md`.

1.7 Appendices

1.7.1 A. Evidence inventory

```
security/
+-- report.md / report.pdf            this report
+-- device-baseline.md                C1 fingerprint baseline
+-- analysis-device-static.md         static findings (RTOS-adapted)
+-- firmware-upgrade-feasibility.md   C7 assessment
+-- firmware/extraction-notes.md      C3 + RBL format + AV pipeline
+-- findings/FW-001..008.md           individual findings
\-- evidence/
    +-- exploits/                     poc01-04 scripts + .out runs + README
    +-- firmware/                     3 × .rbl + hashes.txt
    +-- pcaps/                        cam170-boot-mqtt-http.pcap (+2 minor)
    +-- screenshots/cam170-snapshot.jpg
    +-- mqtt-info-boot.json           version 202503081631 + rotating creds
    \-- ota-confcheck-real-cloud.json real-cloud OTA answers (probed)
```

1.7.2 B. CVSS calculation table

ID	Vector	Score
FW-001	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:L	7.7
FW-002	CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L	6.3
FW-003	CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L	6.3
FW-004	CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	4.3
FW-005	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H	8.1
FW-006	CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L	4.3
FW-007	CVSS:3.1/AV:A/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:L	5.0
FW-008	CVSS:3.1/AV:P/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	6.8

Scores validated with the FIRST `cvss` library (v3.6, python).

1.7.3 C. Limitations & operational notes

- RBL app payloads are encrypted; rootfs-style binary RE (Ghidra on services) was not possible without a hardware flash dump — protocol/app/serial artifacts substituted, marked accordingly.
- FW-005/FW-007/FW-008 current-build behaviour unverified by design (no flashing, no teardown this round).
- Un-sinkhole probe (FW-001/005 evidence) lasted <3 min, camera rebooted once, streams verified up after. BIND gotcha: an RPZ master-file edit with an **unchanged SOA serial** passes `rndc reload` silently without reloading — restore only took effect after a serial bump.
- Device availability: cam170 remained in service throughout; four brief reboots (PoC-triggered, all while idle), auto-reconnect <=2 min each.